

# D-SGSI-08: Guía de Implementación de Controles Críticos (ISO 27002:2022)

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

**Organización:** Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 (Enfoque Zero Trust y Automatización)  
**Basado en:** ISO/IEC 27002:2022

## 1. Matriz de Controles de Vanguardia (Muestra Crítica)

Esta tabla detalla los controles priorizados para los activos críticos de la UNCP (ERP ADESA, Campus Virtual, Datos Personales), integrando los atributos de la norma y mejoras de automatización.

| ID   | Control                                       | Propósito                                        | Atributos<br>(Tipo/CIA/Concepto) | Guía de Implementación<br>Mejorada (Zero Trust /<br>Automatización)                                                                                                                 |
|------|-----------------------------------------------|--------------------------------------------------|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5.7  | <b>Inteligencia de Amenazas</b>               | Proporcionar conciencia del entorno de amenazas. | Preventivo / CIA / Identificar   | <b>Automatización:</b> Integración de feeds de amenazas (OTX, MISP) directamente en el SIEM/WAF para bloquear IPs maliciosas de forma proactiva sin intervención humana.            |
| 8.2  | <b>Derechos de Acceso con Privilegios</b>     | Restringir el acceso a funciones críticas.       | Preventivo / CI / Proteger       | <b>Zero Trust:</b> Acceso Just-In-Time (JIT). Los privilegios de DBA en el ERP ADESA se otorgan solo por el tiempo necesario y bajo aprobación MFA. Nunca confianza permanente.     |
| 8.16 | <b>Seguimiento de Actividades (Monitoreo)</b> | Detectar comportamientos anómalos.               | Detectivo / CIA / Detectar       | <b>Inteligencia:</b> Uso de análisis de comportamiento (UBA) para detectar si un docente accede a notas desde un país inusual o en horario no laboral, disparando alerta inmediata. |
| 8.20 | <b>Seguridad de Redes</b>                     | Proteger la información en las redes.            | Preventivo / CIA / Proteger      | <b>Microsegmentación:</b> Aplicación de ZTNA (Zero Trust Network Access) para que un alumno en el Wi-Fi de la facultad no tenga visibilidad lógica de los servidores de tesorería.  |

| ID   | Control                                   | Propósito                            | Atributos<br>(Tipo/CIA/Concepto) | Guía de Implementación<br>Mejorada (Zero Trust /<br>Automatización)                                                                                                           |
|------|-------------------------------------------|--------------------------------------|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 8.25 | <b>Ciclo de Vida de Desarrollo Seguro</b> | Integrar seguridad en el desarrollo. | Preventivo / CI / Proteger       | <b>DevSecOps:</b> Escaneo automático de vulnerabilidades en el código del ERP ADESA (SAST) antes de cada despliegue a producción en Huawei Cloud.                             |
| 8.31 | <b>Separación de Entornos</b>             | Evitar contaminación de datos.       | Preventivo / CI / Proteger       | <b>Automatización:</b> Los entornos de desarrollo y pruebas se despliegan como “infraestructura como código” (IaC), garantizando que nunca toquen datos reales de producción. |

## 2. Acciones de Mejora (Superando el Estándar)

Para que la UNCP alcance el nivel de madurez deseado en el PGTD, se sugieren las siguientes metodologías de mejora:

### A. Implementación de SOAR (Security Orchestration, Automation, and Response)

- **Concepto:** Superar el SIEM tradicional automatizando la respuesta.
- **Aplicación:** Si el SIEM detecta un ataque de fuerza bruta, el SOAR instruye automáticamente al Firewall perimetral para bloquear la IP atacante y notifica al Oficial de Seguridad por Teams.

### B. Adopción de DevSecOps Integral

- **Concepto:** La seguridad no es una fase, es parte del flujo.
- **Aplicación:** Integrar herramientas de análisis de dependencias (SBOM) para asegurar que ninguna librería utilizada en el Campus Virtual (Moodle) tenga vulnerabilidades conocidas (CVEs).

### C. Estrategia de Salida de Nube (Multi-Cloud / Hybrid Resilience)

- **Concepto:** Evitar el secuestro tecnológico (Vendor Lock-in).
- **Aplicación:** Mantener la capacidad de mover cargas de trabajo críticas (ERP) desde Huawei Cloud hacia un entorno local o una segunda nube pública en menos de 4 horas mediante el uso de contenedores (Kubernetes).

## 3. Restricción de Confidencialidad y Cumplimiento

Todas las recomendaciones contenidas en esta guía están diseñadas para cumplir con la **Ley N° 29733** y el **D.L. N° 1412**. Este documento es para uso interno de la UNCP; su distribución externa requiere la anonimización de activos específicos.

\_\_ **Oficial de Seguridad de la Información** Presidente del Equipo de Respuesta a Incidentes (CSIRT)